Implementing GRC through ISO 27001

1. What is ISO 27001?

- **The Gold Standard:** It is the international standard for an **Information Security Management System (ISMS)**.
- **The Holistic View:** It isn't just about IT; it covers **People, Processes, and Technology**.
- **The Objective:** To protect the **CIA Triad**:
  - **Confidentiality:** Only authorized people can see data.
  - **Integrity:** Data cannot be tampered with.
  - **Availability:** Data is accessible when needed.

---

2. The Connection: GRC vs. ISO 27001

- **GRC is the Strategy:** The high-level "Umbrella" for how a company behaves and stays safe.
- **ISO 27001 is the Blueprint:** The specific, step-by-step instructions used to build the security part of that umbrella.
- **The Result:** ISO 27001 makes GRC "real" and "auditable" rather than just a theoretical concept.

---

3. How ISO 27001 Fits into GRC

Governance (The "G")

- **Management Buy-in:** ISO 27001 requires leadership to approve policies and provide resources.
- **Alignment:** It ensures that security goals match the business goals (e.g., if the business wants to be "Cloud First," the security governance must support that).
- **Accountability:** It defines exactly who is responsible for what.

Risk Management (The "R")

- **Risk-Based Thinking:** You don't secure everything equally. You identify what is most valuable/vulnerable.
- **The Process:** 1. **Identify** the threat (e.g., cyberattack).
  2. **Assess** the impact (e.g., $1M loss).
  3. **Treat** the risk (e.g., install a firewall).
- **Annex A:** This is a "menu" of 93 controls you can choose from to mitigate the risks you find.

Compliance (The "C")

- **Legal & Regulatory:** Helps satisfy laws like GDPR, HIPAA, or local data privacy acts.

- **The "Certificate":** Unlike general GRC, you can get **certified** in ISO 27001.
- **Trust:** Showing a certificate to a client proves you follow international best practices without them having to audit you themselves.

---

4. Key Benefits for the Organization

- **Market Advantage:** Many big companies won't work with vendors unless they are ISO 27001 certified.
- **Consistency:** It moves the company away from "panic mode" security to "systematic" security.
- **Cost Savings:** By focusing on risk, you don't waste money on security tools you don't actually need.

---

5. Summary for the Student

- **GRC** = The "Why" and the "Whole."
- **ISO 27001** = The "How" and the "Proof."
- **Bottom Line:** You cannot have a modern GRC strategy without a framework like ISO 27001 to manage the information security piece.